AI GOVERNANCE · NGÂN HÀNG

AI trong ngân hàng VN có luật riêng từ 15/11/2026

8 việc phải xong trước ngày hiệu lực

Luật AI 134/2025/QH15 · NĐ 142/2026/NĐ-CP
TT 53/2026/TT-NHNN (an toàn & quản lý rủi ro AI)

Vũ Đình Chung
IT Director · Banking & Financial Services · Hà Nội

Vietnam AI Law & SBV AI risk circular — practitioner checklist

BA VĂN BẢN, BA TẦNG NGHĨA VỤ

Ba văn bản mới

01

Luật Trí tuệ nhân tạo 134/2025/QH15

Hiệu lực 01/03/2026 · phân loại rủi ro 3 mức · hành vi bị cấm · nguyên tắc AI phục vụ con người, không thay thế thẩm quyền & trách nhiệm con người

02

NĐ 142/2026/NĐ-CP

Quy định chi tiết thi hành Luật AI

03

TT 53/2026/TT-NHNN

An toàn & quản lý rủi ro AI trong ngân hàng · hiệu lực 15/11/2026 (Điều 14: 01/01/2027; điểm b khoản 1 Điều 6 & Điều 21: 01/09/2027)

Không phải "khuyến nghị": đây là điều kiện triển khai — hệ thống AI đang chạy cũng phải rà soát, phân loại, vào danh mục.

ĐIỀU 4 · PHÂN LOẠI RỦI RO

Phân loại rủi ro là việc đầu tiên

RỦI RO CAO

Tự động thực hiện giao dịch điện tử hoặc quyết định cấp tín dụng giá trị lớn; có thể gây thiệt hại đáng kể

TRUNG BÌNH

Có thể gây nhầm lẫn/thao túng người dùng do không nhận biết được chủ thể tương tác là AI hoặc nội dung do AI tạo ra

THẤP

Không thuộc hai trường hợp trên

Bắt buộc: lập danh mục hệ thống AI + cập nhật hằng năm (Điều 4).

ĐIỀU 5 · KIỂM SOÁT CON NGƯỜI

Tự động hoá khi nào là hợp pháp?

- Chỉ tự động khi pháp luật không buộc phải có sự xem xét/quyết định/phê duyệt của con người.
- Phải có khả năng can thiệp, dừng hệ thống bất cứ lúc nào.
- Phải xác định được giao dịch nào do AI tự động, giao dịch nào do con người thực hiện.
- Giao dịch thanh toán tự động: cần thỏa thuận với khách hàng + yêu cầu an toàn theo TT 50/2024/TT-NHNN.
- AI tự động quyết định cấp tín dụng: tuân thủ quy định cho vay điện tử (TT 39/2016 + TT 29/2026).

ĐIỀU 6 · AN NINH HỆ THỐNG AI

Kiểm thử AI theo kịch bản tấn công

Đánh giá an ninh trước khi vận hành chính thức, định kỳ, và khi có thay đổi đáng kể.

- Prompt injection · rò rỉ thông tin nhạy cảm
- Tấn công trích xuất mô hình (model extraction)
- Đầu độc dữ liệu huấn luyện (data poisoning)
- Rò rỉ system prompt · lỗ hổng vector/embedding
- Chuỗi cung ứng AI · quyền hạn quá mức
- Đầu ra sai · tiêu thụ tài nguyên không giới hạn

ĐIỀU 7 · DỮ LIỆU & QUYỀN RIÊNG TƯ

Dữ liệu huấn luyện phải có nguồn gốc

- Dữ liệu dùng để huấn luyện, kiểm thử, vận hành phải có nguồn gốc hợp pháp.
- Tuân thủ pháp luật dữ liệu, bảo vệ dữ liệu cá nhân, sở hữu trí tuệ.
- Luật 91/2025/QH15 + NĐ 356/2025/NĐ-CP (từ 01/01/2026): đồng ý cụ thể, tách bạch; DPIA; báo lộ dữ liệu nhạy cảm trong 72 giờ.
- Cloud nước ngoài = chuyển dữ liệu xuyên biên giới → DPIA + TIA.
- Dùng scoring/Open API: xem cơ chế sandbox NĐ 94/2025/NĐ-CP.

ĐIỀU 8–9 · THAY ĐỔI, SỰ CỐ, BÊN THỨ BA

Quản lý phiên bản, sự cố & vendor

VERSIONING MÔ HÌNH

Thông tin phiên bản; thời điểm áp dụng/thay đổi/ngừng; phạm vi ảnh hưởng; cấu hình; nhật ký thay đổi; kết quả kiểm tra

XỬ LÝ SỰ CỐ AI

Quy trình xử lý sự cố đặc thù AI + phương án nghiệp vụ; sự cố nghiêm trọng kích hoạt ngay ứng cứu

RỦI RO BÊN THỨ BA

Đánh giá rủi ro do phụ thuộc nhà cung cấp LLM/nền tảng/dữ liệu; hợp đồng, data residency, exit plan

TRƯỚC 15/11/2026

8 việc phải xong

01 Lập danh mục hệ thống AI

02 Phân loại rủi ro từng hệ thống

03 Thiết kế kiểm soát con người + điều kiện tự động hoá

04 Quy trình đánh giá an ninh AI (trước go-live, định kỳ)

05 Chính sách nguồn gốc dữ liệu + DPIA/TIA

06 Versioning mô hình/prompt

07 Quy trình xử lý sự cố AI

08 Đánh giá rủi ro bên thứ ba (LLM/vendor)

Danh mục? Phân loại? Log? — Nếu chưa có, đó là 3 câu đầu tiên nên hỏi.

Chi tiết + nguồn pháp lý:
dinhchung82.github.io/banking-tech-study